RB-802: Leaked API Key

Field	Value
Service	Partner API keys (prefix sk_live_) and internal service tokens
Severity	SEV-1 until the key is revoked, then SEV-2
Owner	Security team
Last reviewed	2026-10-08

1. Symptoms

- Alert SecretScanningAlert is posted to #security-alerts when GitHub secret scanning or the gitleaks CI step finds a live key in a commit, issue or pull request.
- A partner or a researcher reports a key through security@example.com or the bug bounty program.
- Alert ApiKeyAnomalousUsage fires when a key is used from more than 5 new countries or above 10x its 7-day average request rate.

2. Response timeline

The clock starts when the alert is posted, not when someone reads it.

Step	Deadline
Revoke the key	15 minutes
Audit log search done	1 hour
Owner and partner notified	4 hours
Legal informed if personal data was read	24 hours (GDPR clock is 72 hours)
Post-incident report published	5 business days

3. Containment

3.1 Identify the key

The alert links the commit. Find the key id from its first 12 characters, which are safe to paste in chat:

```
apikeyctl lookup --prefix sk_live_4f9a
```

The output gives the key id, the owning partner or service, its scopes and the date it was last used.

3.2 Revoke the key

Revoke first and investigate afterwards. A key that has been public for even a few seconds must be treated as stolen: bots scrape public repositories within minutes.

```
apikeyctl revoke --id key_8d21c7 --reason "leaked in public repo" --incident INC-2026-1101
```

Revocation reaches every API gateway within 60 seconds. Requests with the key then get 401 invalid_api_key.

Warning: do not rely on deleting the commit or force-pushing the repository history. Forks, caches and scrapers keep the key. Revoke the key before cleaning up the repository, and never paste the full key in Slack or in the ticket.

4. Investigation

4.1 Search the audit log

Requests are logged in the OpenSearch index pattern api-audit-*, kept for 90 days. Search every request made with the key id since the leaking commit, minus 24 hours:

```
curl -s -u "$OS_USER" "https://opensearch.internal.example.com/api-audit-*/_search" \
  -H 'Content-Type: application/json' \
  -d '{"query":{"term":{"api_key_id":"key_8d21c7"}},"size":500,"sort":[{"@timestamp":"asc"}]}'
```

4.2 Decide on the impact

Compare source IPs and user agents with the owner's normal traffic. Any request from an unknown IP to an endpoint that returns customer data (/v2/customers, /v2/orders) counts as a data exposure and must go to Legal. Record each finding in the incident ticket.

5. Recovery

5.1 Issue a replacement key

Create a new key with the same scopes, never wider, and store it in Vault so it is not sent by email:

```
apikeyctl create --owner partner-acme --scopes orders:read,orders:write
vault kv put secret/partners/partner-acme api_key=@new_key.txt
```

Share the Vault path with the partner through the partner portal. The replacement key must be issued within 4 hours of revocation for production partners.

5.2 Notify the owner

The Security on-call writes to the key owner using the "Key revoked" template, with the time of revocation, the audit result and the replacement procedure. Partners with a contract SLA are also called by their account manager.

6. Escalation

Level	Who	Contact
L1	On-call SRE	#ops-oncall
L2	Security on-call	PagerDuty: security-oncall

L3	CISO and Legal	any confirmed customer data exposure